

Atelier 8

* * *

A08 - Software and Data Integrity Failures

El Azzouzi aya

Objectif global

Mettre en œuvre les bonnes pratiques OWASP pour la sécurité des dépendances :

1. Créer un projet Maven dans Eclipse
2. Générer un SBOM (Software Bill of Materials)
3. Scanner les dépendances pour détecter les vulnérabilités connues
4. Vérifier les signatures PGP (intégrité et authenticité)

1. Étape 1 – Création du projet Maven

Objectif

Avoir une base de projet Java fonctionnelle avec des dépendances.

Actions

Créez un projet Maven avec ce POM :

```
<project xmlns="http://maven.apache.org/POM/4.0.0"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://maven.apache.org/POM/4.0.0
    https://maven.apache.org/xsd/maven-4.0.0.xsd">
  <modelVersion>4.0.0</modelVersion>

  <groupId>com.example</groupId>
  <artifactId>demo-a08</artifactId>
  <version>1.0.0</version>

  <properties>
```

```

    <maven.compiler.source>17</maven.compiler.source>
    <maven.compiler.target>17</maven.compiler.target>
</properties>

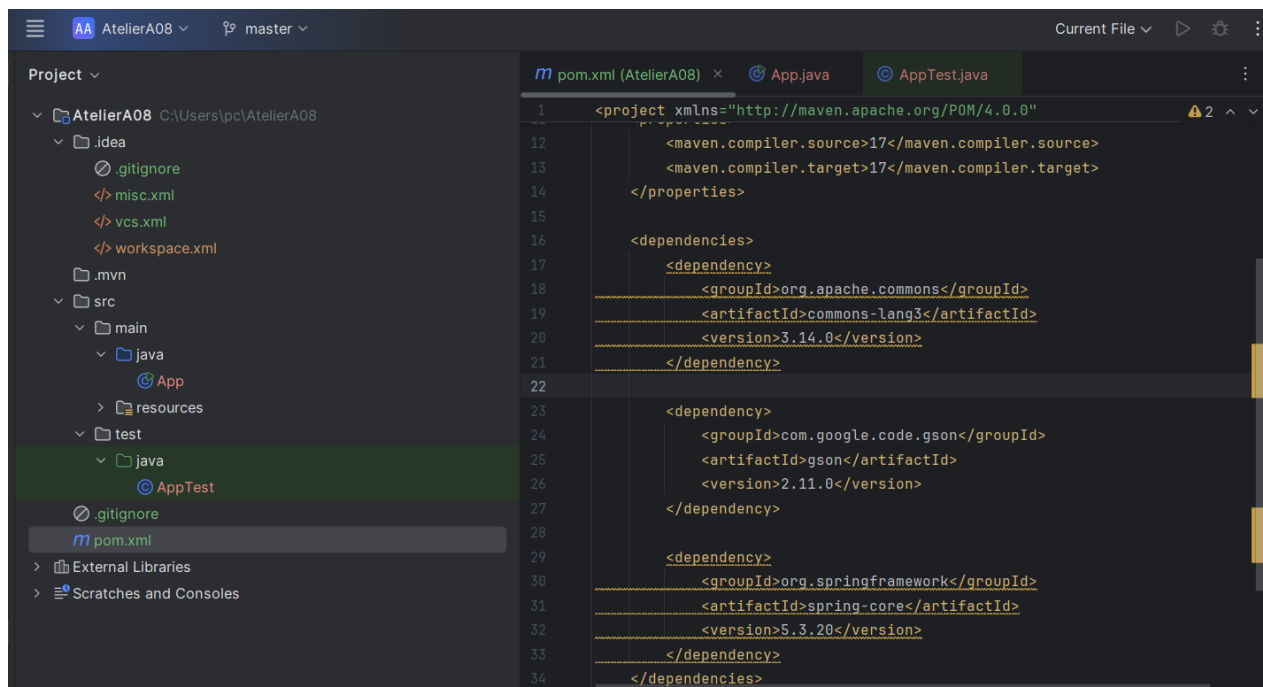
<dependencies>
  <dependency>
    <groupId>org.apache.commons</groupId>
    <artifactId>commons-lang3</artifactId>
    <version>3.14.0</version>
  </dependency>

  <dependency>
    <groupId>com.google.code.gson</groupId>
    <artifactId>gson</artifactId>
    <version>2.11.0</version>
  </dependency>

  <dependency>
    <groupId>org.springframework</groupId>
    <artifactId>spring-core</artifactId>
    <version>5.3.20</version>
  </dependency>
</dependencies>
</project>

```

1.



```
m pom.xml (AtelierA08) x </> bom.xml bom.json App.java AppTest.java
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
2     xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
3     xsi:schemaLocation="http://maven.apache.org/POM/4.0.0
4         https://maven.apache.org/xsd/maven-4.0.0.xsd">
5     <modelVersion>4.0.0</modelVersion>
6
7     <groupId>com.example</groupId>
8     <artifactId>AtelierA08</artifactId>
9     <version>1.0.0</version>
10
11     <properties>
12         <maven.compiler.source>17</maven.compiler.source>
13         <maven.compiler.target>17</maven.compiler.target>
14     </properties>
15
16     <build>
17         <plugins>
18             <plugin>
19                 <groupId>org.owasp</groupId>
20                 <artifactId>dependency-check-maven</artifactId>
21                 <version>10.0.3</version>
22                 <executions>
23                     <execution>
24                         <goals>
```

Créez la classe App.java :

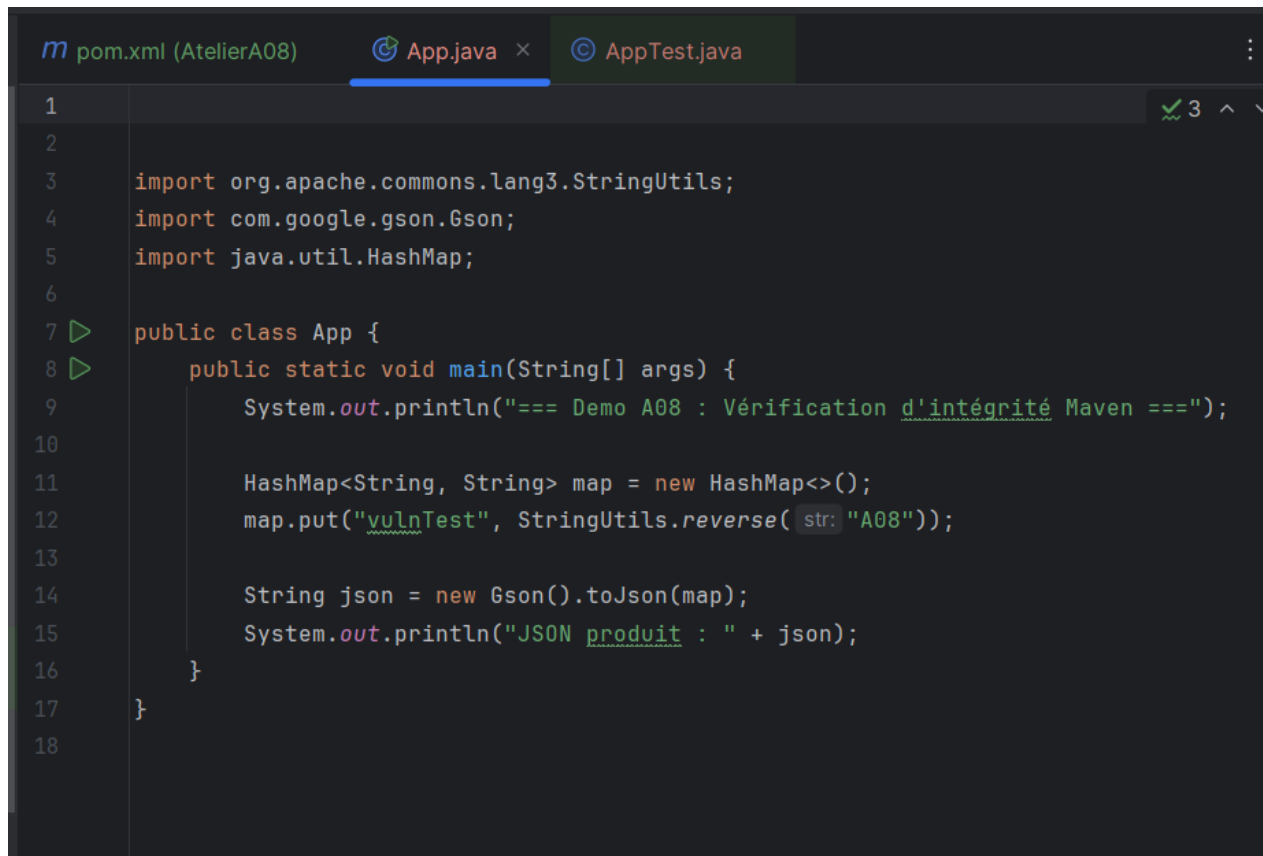
```
package com.app;

import org.apache.commons.lang3.StringUtils;
import com.google.gson.Gson;
import java.util.HashMap;

public class App {
    public static void main(String[] args) {
        System.out.println("=== Demo A08 : Vérification d'intégrité Maven  
===");

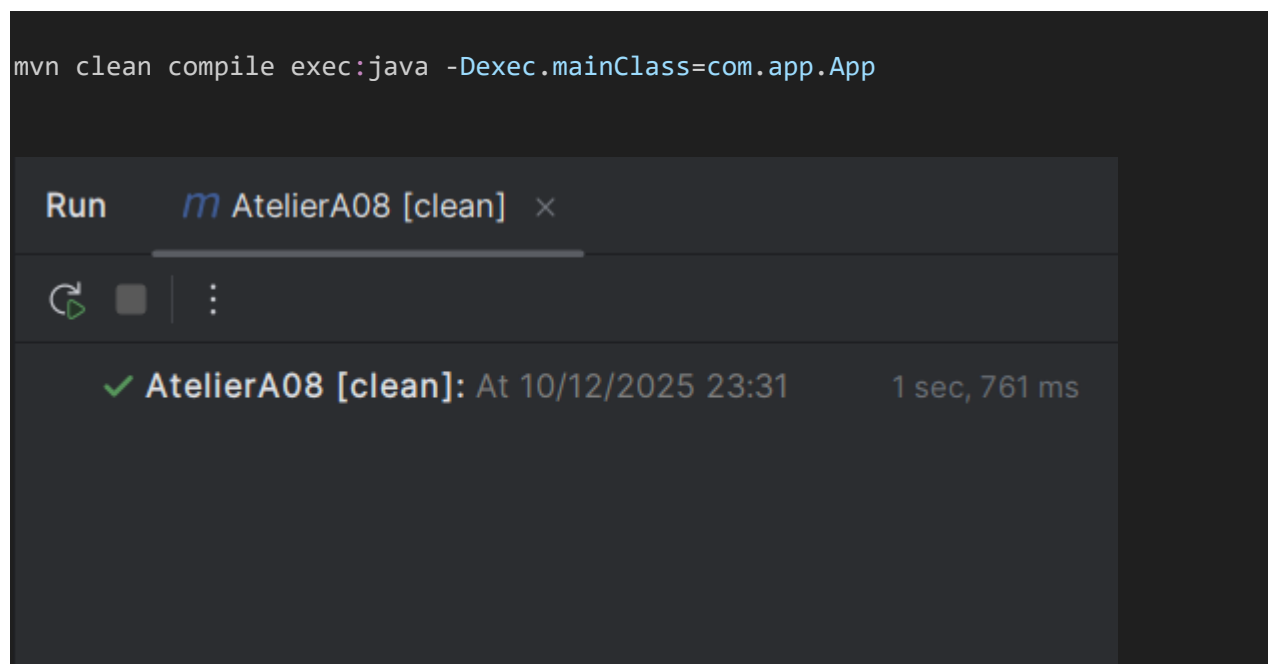
        HashMap<String, String> map = new HashMap<>();
        map.put("vulnTest", StringUtils.reverse("A08"));

        String json = new Gson().toJson(map);
        System.out.println("JSON produit : " + json);
    }
}
```



```
1
2
3 import org.apache.commons.lang3.StringUtils;
4 import com.google.gson.Gson;
5 import java.util.HashMap;
6
7 public class App {
8     public static void main(String[] args) {
9         System.out.println("=== Demo A08 : Vérification d'intégrité Maven ===");
10
11         HashMap<String, String> map = new HashMap<>();
12         map.put("vulnTest", StringUtils.reverse(str: "A08"));
13
14         String json = new Gson().toJson(map);
15         System.out.println("JSON produit : " + json);
16     }
17 }
18
```

Compilez :



```
mvn clean compile exec:java -Dexec.mainClass=com.app.App
```

Run AtelierA08 [clean] ×

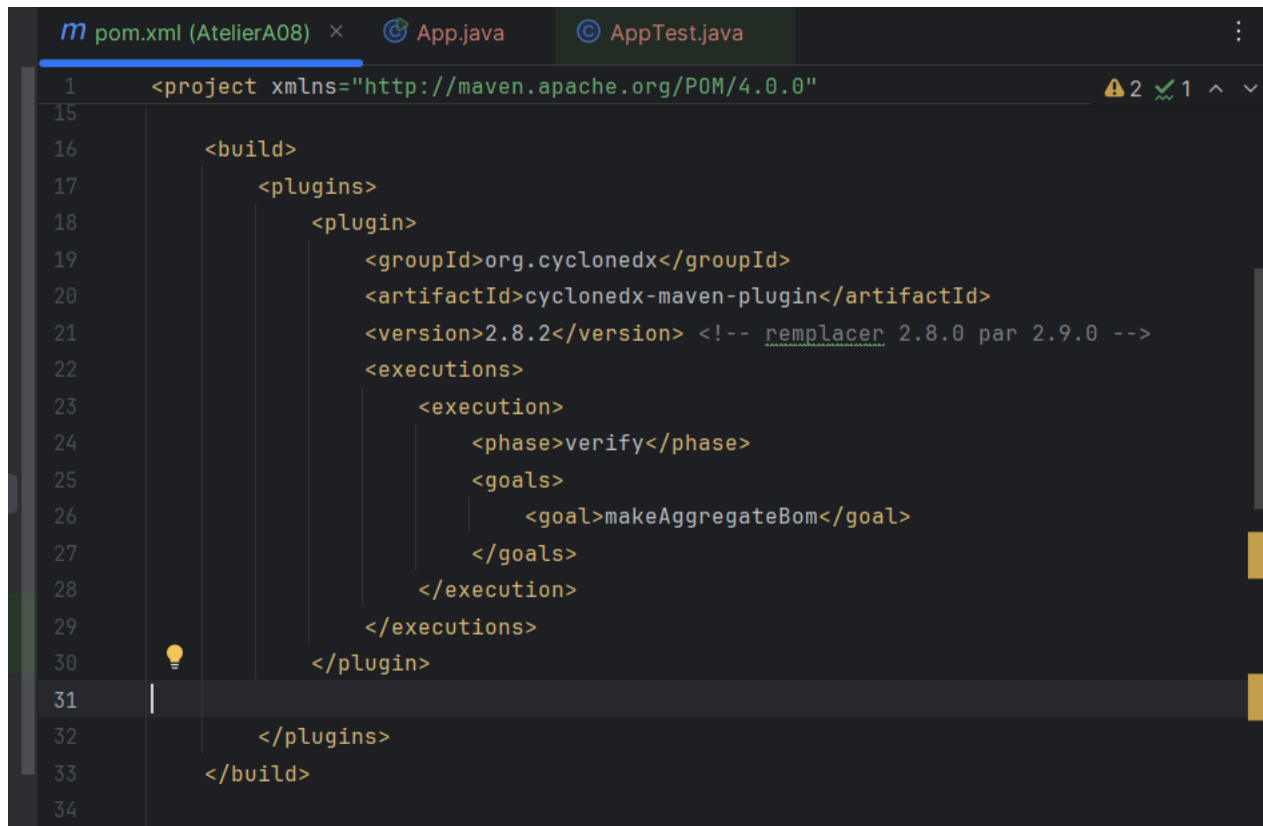
✓ AtelierA08 [clean]: At 10/12/2025 23:31 1 sec, 761 ms

2. Génération d'un SBOM (Software Bill of Materials)

Objectif

Lister toutes les bibliothèques du projet. Pour ce faire, ajouter dans POM le plugin suivant :

```
<build>
  <plugins>
    <plugin>
      <groupId>org.cyclonedx</groupId>
      <artifactId>cyclonedx-maven-plugin</artifactId>
      <version>2.8.0</version>
      <executions>
        <execution>
          <phase>verify</phase>
          <goals>
            <goal>makeAggregateBom</goal>
          </goals>
        </execution>
      </executions>
    </plugin>
  </plugins>
</build>
```



```
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
15
16 <build>
17 <plugins>
18 <plugin>
19 <groupId>org.cyclonedx</groupId>
20 <artifactId>cyclonedx-maven-plugin</artifactId>
21 <version>2.8.2</version> <!-- remplacer 2.8.0 par 2.9.0 -->
22 <executions>
23 <execution>
24 <phase>verify</phase>
25 <goals>
26 <goal>makeAggregateBom</goal>
27 </goals>
28 </execution>
29 </executions>
30 </plugin>
31
32 </plugins>
33 </build>
34
```

Vérifiez :

```
mvn verify
```

```

PS C:\Users\pc\AtelierA08> mvn verify
[INFO] Scanning for projects...
[INFO]
[INFO] -----< com.example:AtelierA08 >-----
[INFO] Building AtelierA08 1.0.0
[INFO]   from pom.xml
[INFO] -----[ jar ]-----
[INFO]
[INFO] --- resources:3.3.1:resources (default-resources) @ AtelierA08 ---
[WARNING] Using platform encoding (UTF-8 actually) to copy filtered resources, i.e. build is platform dependent!
[INFO] Copying 1 resource from src\main\resources to target\classes
[INFO]
[INFO] --- compiler:3.13.0:compile (default-compile) @ AtelierA08 ---
[INFO] Nothing to compile - all classes are up to date.
[INFO]
[INFO] --- resources:3.3.1:testResources (default-testResources) @ AtelierA08 ---
[WARNING] Using platform encoding (UTF-8 actually) to copy filtered resources, i.e. build is platform dependent!
[INFO] skip non existing resourceDirectory C:\Users\pc\AtelierA08\src\test\resources
[INFO]
[INFO] --- compiler:3.13.0:testCompile (default-testCompile) @ AtelierA08 ---
[INFO] Nothing to compile - all classes are up to date.
[INFO]
[INFO] --- surefire:3.2.5:test (default-test) @ AtelierA08 ---
[INFO] Using auto detected provider org.apache.maven.surefire.junit.JUnit3Provider
[INFO]
[INFO] -----
[INFO] T E S T S
[INFO] -----
[INFO] Running AppTest
[INFO] Tests run: 0, Failures: 0, Errors: 0, Skipped: 0, Time elapsed: 0 s -- in AppTest
[INFO]
[INFO] Results:
[INFO]
[INFO] Tests run: 0, Failures: 0, Errors: 0, Skipped: 0

```

```

[INFO] Results:
[INFO]
[INFO] Tests run: 0, Failures: 0, Errors: 0, Skipped: 0
[INFO]
[INFO]
[INFO] --- jar:3.4.1:jar (default-jar) @ AtelierA08 ---
[INFO]
[INFO] --- cyclonedx:2.7.10:makeAggregateBom (default) @ AtelierA08 ---
Downloading from central: https://repo.maven.apache.org/maven2/com/google/quava/quava/16.0.1/quava-16.0.1.jar
Downloaded from central: https://repo.maven.apache.org/maven2/com/google/quava/quava/16.0.1/quava-16.0.1.jar (2.2 MB at 1.7 MB/s)
[INFO] CycloneDX: Resolving Dependencies
[INFO] CycloneDX: Creating BOM version 1.4 with 5 component(s)
[INFO] CycloneDX: Writing and validating BOM (XML): C:\Users\pc\AtelierA08\target\bom.xml
[INFO]   attaching as AtelierA08-1.0.0-cyclonedx.xml
[INFO] CycloneDX: Writing and validating BOM (JSON): C:\Users\pc\AtelierA08\target\bom.json
[WARNING] Unknown keyword additionalItems - you should define your own Meta Schema. If the keyword is irrelevant for validation, just use a NonValidationKeyword
[INFO]   attaching as AtelierA08-1.0.0-cyclonedx.json
[INFO] -----
[INFO] BUILD SUCCESS
[INFO] -----
[INFO] Total time: 5.039 s
[INFO] Finished at: 2025-12-11T09:31:10+01:00
[INFO] -----
PS C:\Users\pc\AtelierA08>

```

Résultat attendu

Un fichier target/bom.json contenant :

```

{
  "components": [
    { "name": "spring-core", "version": "5.3.20" },
    { "name": "gson", "version": "2.11.0" },
    { "name": "commons-lang3", "version": "3.14.0" }
  ]
}

```

```
m pom.xml (AtelierA08)  </> bom.xml  bom.json x  App.java  AppTest.java
1  {
2    "bomFormat" : "CycloneDX",
3    "specVersion" : "1.4",
4    "serialNumber" : "urn:uuid:738488f7-9f56-43c1-8a10-7205e11b6f92",
5    "version" : 1,
6    "metadata" : {
7      "timestamp" : "2025-12-11T08:31:09Z",
8      "tools" : [
9        {
10         "vendor" : "OWASP Foundation",
11         "name" : "CycloneDX Maven plugin",
12         "version" : "2.7.10",
13         "hashes" : [
14           {
15             "alg" : "MD5",
16             "content" : "1cc7f6a0382f8bb2f758d6a6ea401d1b"
17           },
18           {
19             "alg" : "SHA-1",
20             "content" : "a4297947a1f2d7d453105db542651614bbd37f38"
21           },
22           {
23             "alg" : "SHA-256",
24             "content" : "bd0fdd8f2f2116eee5e715aeac1580f19eb7a10ec2b6f805b53567067658e872"
25           },
26           {
27             "alg" : "SHA-512",
28             "content" : "9cde8352a427e10b96cae01348fc7cfe5d4aa9cd0a5e5dd93b414ce3bb7d112993c3b3004e53af52567fbf
29           }
30         ]
31       }
32     }
33   }
```

3. Scanner les dépendances (SCA)

Objectif

Identifier les vulnérabilités connues.

Plugin OWASP Dependency-Check

Ajoutez le plugin suivant dans le build de votre POM.

```
<plugin>
  <groupId>org.owasp</groupId>
  <artifactId>dependency-check-maven</artifactId>
  <version>10.0.3</version>
  <executions>
    <execution>
      <goals>
        <goal>check</goal>
      </goals>
    </execution>
  </executions>
</plugin>
```

```
</executions>
</plugin>
```

Exécution PowerShell

```
mvn org.owasp:dependency-check-maven:check
```

Résultat

Rapport généré : target/dependency-check-report.html

Ouvrez-le dans le navigateur pour visualiser les CVE et leur gravité.

4. Vérifier les signatures PGP

Objectif

S'assurer que les artefacts téléchargés proviennent bien de leurs éditeurs officiels.

Plugin PGPVerify

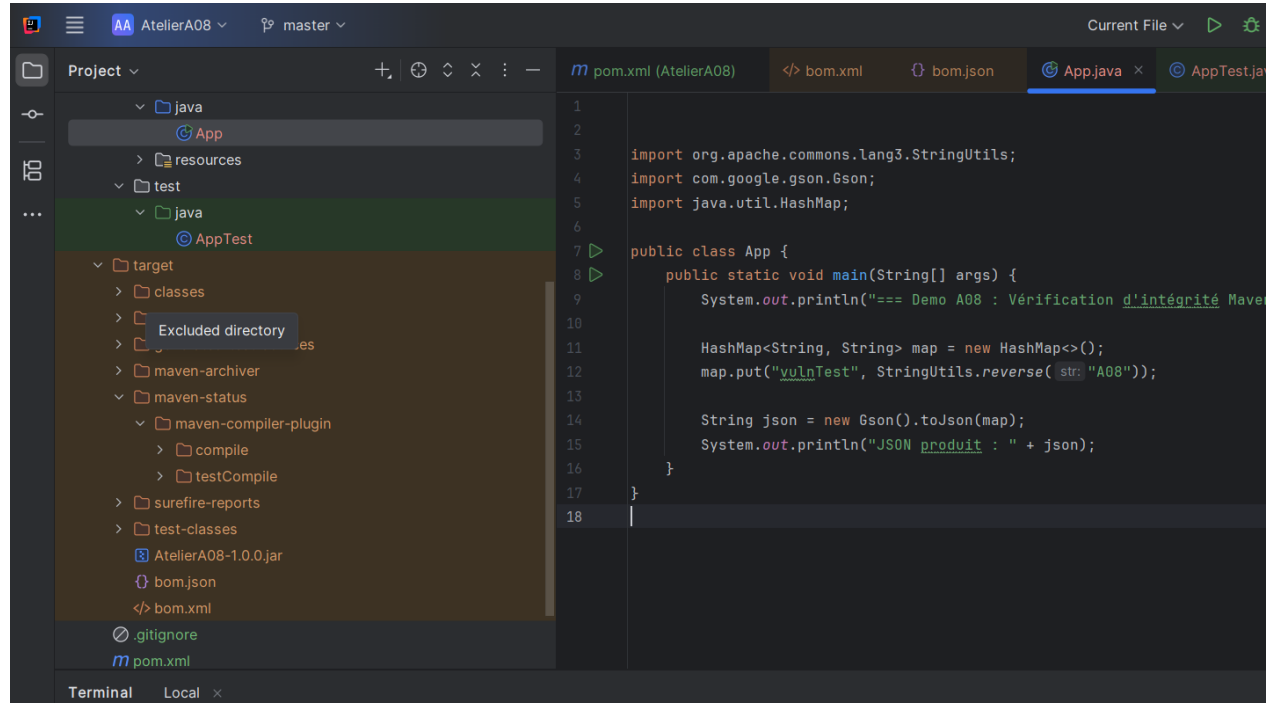
```
<plugin>
  <groupId>org.simplify4u.plugins</groupId>
  <artifactId>pgpverify-maven-plugin</artifactId>
  <version>1.19.1</version>
  <configuration>
    <keysMapLocation>/pgp-keys-map.list</keysMapLocation>
    <reportWrite>true</reportWrite>
    <disableChecksum>true</disableChecksum>
  </configuration>
  <dependencies>
    <dependency>
      <groupId>org.simplify4u</groupId>
      <artifactId>pgp-keys-map</artifactId>
      <version>2025.03.15</version>
    </dependency>
  </dependencies>
  <executions>
    <execution>
      <phase>verify</phase>
      <goals><goal>check</goal></goals>
    </execution>
  </executions>
</plugin>
```

```
</executions>
</plugin>
```

Exécution PowerShell

mvn verify

```
Terminal Local x + v
PS C:\Users\assia\IdeaProjects\securityTp> mvn verify
[INFO] Scanning for projects...
[INFO] -----< com.example:securityTp >-----
[INFO] Building securityTp 1.0-SNAPSHOT
[INFO] from pom.xml
[INFO] -----[ jar ]-----
Downloading from central: https://repo.maven.apache.org/maven2/org/cyclonedx/cyclonedx-maven-plugin/2.8.0/cyclonedx-maven-plugin-2.8.0.pom
Downloading from central: https://repo.maven.apache.org/maven2/org/cyclonedx/cyclonedx-maven-plugin/2.8.0/cyclonedx-maven-plugin-2.8.0.pom (19 kB at 15.9 kB/s)
Downloading from central: https://repo.maven.apache.org/maven2/org/cyclonedx/cyclonedx-maven-plugin/2.8.0/cyclonedx-maven-plugin-2.8.0.jar
Downloading from central: https://repo.maven.apache.org/maven2/org/cyclonedx/cyclonedx-maven-plugin/2.8.0/cyclonedx-maven-plugin-2.8.0.jar (50 kB at 90.4 kB/s)
[WARNING] Version not locked for default bindings plugins [maven-resources-plugin, maven-compiler-plugin, maven-surefire-plugin, maven-jar-plugin], you should
define versions in pluginManagement section of your pom.xml or parent
[INFO] --- resources:3.3.1:resources (default-resources) @ securityTp ---
[INFO] skip non existing resourceDirectory C:\Users\assia\IdeaProjects\securityTp\src\main\resources
[INFO] --- compiler:3.13.0:compile (default-compile) @ securityTp ---
[INFO] Nothing to compile - all classes are up to date.
[INFO] --- resources:3.3.1:testResources (default-testResources) @ securityTp ---
[INFO] skip non existing resourceDirectory C:\Users\assia\IdeaProjects\securityTp\src\test\resources
[INFO] --- compiler:3.13.0:testCompile (default-testCompile) @ securityTp ---
[INFO] No sources to compile
[INFO] --- surefire:3.5.2:test (default-test) @ securityTp ---
[INFO] No tests to run.
[INFO]
```



Résultat attendu

```
"components" : [
  {
    "publisher" : "The Apache Software Foundation",
    "group" : "org.apache.commons",
    "name" : "commons-lang3",
    "version" : "3.14.0",
    "description" : "Apache Commons Lang, a package of Java utility classes for the classes that a",
    "scope" : "required",
    "hashes" : [
      {
        "alg" : "MD5",
        "content" : "4e5c3f5e6b0b965ef241d7d72ac8971f"
      },
      {
        "alg" : "SHA-1",
        "content" : "1ed471194b02f2c6cb734a0cd6f6f107c673afae"
      }
    ]
  }
]

SPRING-CORE :
```

[INFO] org.springframework:spring-core:jar:5.3.20 PGP Signature OK
[INFO] com.google.code.gson:gson:jar:2.11.0 PGP Signature OK
[INFO] org.apache.commons:commons-lang3:jar:3.14.0 PGP Signature OK
[INFO] BUILD SUCCESS

5. Synthèse

Étape	Objectif	Outil	Commande PowerShell	OWASP
1	Création projet Maven	Eclipse	mvn compile	-
2	Inventaire des composants	CycloneDX	mvn verify	A06 / A08
3	Analyse de vulnérabilités	Dependency-Check	mvn dependency-check:check	A06
4	Vérification d'intégrité	PGPVerify	mvn verify	A08